# Healthcare IAM - HIPAA Workforce Termination Risk Assessment

NIST SP-800-66 rev2 (HIPAA)

Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A Cybersecurity Resource Guide, 2.0.0
Source: https://csrc.nist.gov/Projects/cprt/catalog#/cprt/framework/version/SP800_66_2_0_0/home

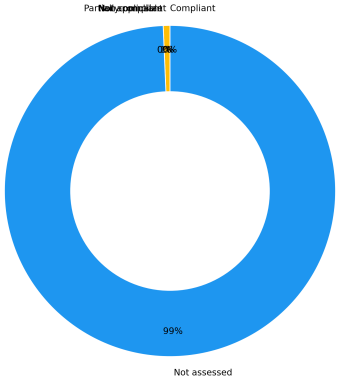
| | |
|---|---|
| **Reference** | CAN-AUD-HIPAA-001 |
| **Date** | 03/11/2026 |
| **Implementation groups** | All |
| **Contributors** | , |

Generated at 2026-11-03 20:32:57 UTC
Document ID 919117ba-6b58-4823-ad57-f7a45174e4df

# Executive summary

| Compliant | Partially compliant | Non compliant | Not applicable | Not assessed |
|---|---|---|---|---|
| 0 | 1 | 0 | 0 | 151 |

Compliant on **0%** of 152 assessed requirements. 1 applied controls are linked to this audit.







## Scope

This audit evaluates workforce identity and access management controls within the Care Access Navigator healthcare IAM and GRC capstone project, using NIST SP 800-66 Rev. 2 as guidance for the HIPAA Security Rule.

The assessment focuses on workforce termination procedures, account deprovisioning, access revocation, and verification across Microsoft Entra ID, Keycloak, and the Mock EHR application.

It uses the documented termination of Jeevan Smith (TERM-2026-0301) to evaluate the existing manual JML control (CAN-CTRL-JML-001), identify the Keycloak deprovisioning gap, and track the planned automated remediation (CAN-CTRL-JML-002).

Supporting evidence includes JML lifecycle records, access revocation verification, and the related risk scenario R02. The audit will document control effectiveness, compliance gaps, corrective actions, and outstanding risks.

This is a simulated, HIPAA-aligned assessment for educational purposes and does not certify regulatory compliance.

## Drifts per domain

| Domain | Findings |
|---|---|
| 164.308 | 67 |
| 164.310 | 24 |
| 164.312 | 34 |
| 164.314 | 18 |
| 164.316 | 9 |

# Detailed results

152 assessable requirements.

### - — 1. Identify all ePHI and Relevant Information Systems

Not assessed

**Progress:** To do

Identify where ePHI is generated within the organization, where it enters the organization, where it moves within the organization, where it is stored, and where it leaves the organization.

Identify all systems  that house ePHI. Be sure to identify mobile devices, medical equipment, and medical IoT devices that store, process, or transmit ePHI.

Include all hardware and software that are used to collect, store, process, or transmit ePHI.

Analyze business functions and verify the ownership and control of information system elements as necessary.

Consider the impact of a merger or acquisition on risks to ePHI. During a merger or acquisition, new data pathways may be introduced that lead to ePHI being stored, processed, or transmitted in previously unanticipated places.

**Has all ePHI generated, stored, processed, and transmitted within the organization been identified?**

-

**Are all hardware and software for which the organization is responsible periodically inventoried?**

-

**Is the hardware and software inventory updated on a regular basis?**

-

**Have hardware and software that maintains or transmits ePHI been identified?**

-

**Does this inventory include removable media and remote access devices?**

-

**Is the current configuration of organizational systems documented, including connections to other systems?**

-

**Has a BIA been performed?**

-

### - — 2. Conduct Risk Assessment

Not assessed

**Progress:** To do

Conduct an accurate and thorough assessment of the potential risks and vulnerabilities to the confidentiality, integrity, and availability of ePHI held by the covered entity or business associate.

**Are there any prior risk assessments, audit comments, security requirements, and/or security test results?**

-

**Is there intelligence available from agencies, the Office of the Inspector General (OIG), the US-CERT, virus alerts, and/or vendors?**

-

**What are the human, natural, and environmental threats to systems that contain, store, process, or transmit ePHI?**

-

**What are the current and planned controls?**

-

**Have likelihood and impact been determined for relevant threats and vulnerabilities?**

-

**Have risk ratings been determined for relevant threats and vulnerabilities?**

-

**Is the facility located in a region prone to any natural disasters, such as earthquakes, floods, or fires?**

-

**Has responsibility been assigned to check all hardware and software – including hardware and software used for remote access – to determine whether selected security settings are enabled?**

-

**Is there an analysis of current safeguards and their effectiveness relative to the identified risks?**

-

**Have all processes involving ePHI been considered, including creating, receiving, maintaining, and transmitting it?**

-

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

Conduct an accurate and thorough assessment of the potential risks and vulnerabilities to the confidentiality, integrity, and availability of ePHI held by the covered entity or business associate.

### - — 3. Implement a Risk Management Program

Not assessed

**Progress:** To do

Implement security measures sufficient to reduce risks and vulnerabilities to a reasonable and appropriate level to comply with §164.306(a).

Risk management should be performed with regular frequency to examine past decisions, reevaluate risk likelihood and impact levels, and assess the effectiveness of past remediation efforts

Create a Risk Management policy and program that outlines organizational risk appetite and risk tolerance, personnel duties, responsible parties, the frequency of risk management, and required documentation.

A risk management methodology is included in Section 4.

Risk management resources are also included in Appendix F.

**Is executive leadership and/or management involved in risk management decisions?**

-

**Has a risk management program been created with related policies?**

-

**Does the regulated entity need to engage other resources (e.g., external expertise) to assist in risk management?**

-

**Do current safeguards ensure the confidentiality, integrity, and availability of all ePHI?**

-

**Do current safeguards protect against reasonably anticipated uses or disclosures of ePHI that are not permitted by the Privacy Rule?**

-

**Has the regulated entity used the results of risk assessment and risk management processes to guide the selection and implementation of appropriate controls to protect ePHI?**

-

**Has the regulated entity protected against all reasonably anticipated threats or hazards to the security and integrity of ePHI?**

-

**Has the regulated entity assured compliance with all policies and procedures by its workforce?**

-

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

Implement security measures sufficient to reduce risks and vulnerabilities to a reasonable and appropriate level to comply with §164.306(a)

### - — 4. Acquire IT Systems and Services

Not assessed

**Progress:** To do

Regulated entities should consider how cloud services and other third-party IT system and service offerings can both assist regulated entities in protecting ePHI while also potentially introducing new risks to ePHI.

Although the HIPAA Security Rule does not require purchasing any particular technology, adequately protecting information may require additional hardware, software, or services. Considerations for their selection should include the following:

**Will new security controls work with the existing IT architecture?**

-

**Have the security requirements of the organization been compared to the security features of existing or proposed hardware and software?**

-

**Has a cost-benefit analysis been conducted to determine the reasonableness of the investment given the security risks identified?**

-

**Has a training strategy been developed?**

-

### - — 5. Create and Deploy Policies and Procedures

Not assessed

**Progress:** To do

Implement the decisions concerning the management, operational, and technical controls selected to mitigate identified risks.

Create policies that clearly establish roles and responsibilities, and assign ultimate responsibility for the implementation of each control to particular individuals or offices.

Create procedures to be followed to accomplish particular security-related tasks.

Establish a frequency for reviewing policy and procedures

**Has the regulated entity documented an organizational risk assessment/management policy that outlines the duties, responsible parties, frequency, and required documentation of the risk management program?**

-

**Are policies and procedures in place for security?**

-

**Is there a formal (documented) system security plan?**

-

**Is there a formal contingency plan?**

-

**Is there a process for communicating policies and procedures to the affected workforce members?**

-

**Are policies and procedures reviewed and updated as needed?**

-

### - — 6. Develop and Implement a Sanction Policy

Not assessed

**Progress:** To do

Apply appropriate sanctions against workforce members who fail to comply with the security policies and procedures of the covered entity or business associate

Develop policies and procedures for imposing appropriate sanctions (e.g., reprimand, termination) for noncompliance with the organization's security policies.

Implement sanction policy as cases arise.

**Does the regulated entity have existing sanction policies and procedures to meet the requirements of this implementation specification?**

-

**If not, can existing sanction policies be modified to include language related to violations of these policies and procedures?**

-

**Is there a formal process in place to address system misuse, abuse, and fraudulent activity?**

-

**Have workforce members been made aware of policies concerning sanctions for inappropriate access, use, and disclosure of ePHI?**

-

**Has the need and appropriateness of a tiered structure of sanctions that accounts for the magnitude of harm and possible types of inappropriate disclosures been considered?**

-

**How will managers and workforce members be notified regarding suspect activity?**

-

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

Apply appropriate sanctions against workforce members who fail to comply with the security policies and procedures of the covered entity or business associate

### - — 7. Develop and Deploy the Information System Activity Review Process

Not assessed

**Progress:** To do

Implement procedures to regularly review records of information system activity, such as audit logs, access reports, and security incident tracking reports.

Implement regular reviews of information system activity, and consider ways to automate the review for the protection of ePHI.

**Is there a policy that establishes what reviews will be conducted?**

-

**Are there corresponding procedures that describe the specifics of the reviews?**

-

**Who is responsible for the overall process and results?**

-

**How often will reviews take place?**

-

**How often will review results be analyzed?**

-

**Has the regulated entity considered all available capabilities to automate the reviews?**

-

**Where will audit information reside (e.g., separate server)?**

-

**Will it be stored external to the organization (e.g., cloud service provider)?**

-

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

Implement procedures to regularly review records of information system activity, such as audit logs, access reports, and security incident tracking reports.

### - — 8. Develop Appropriate Standard Operating Procedures

Not assessed

**Progress:** To do

Determine the types of audit trail data and monitoring procedures that will be needed to derive exception reports.

**How will exception reports or logs be reviewed?**

-

**Where will monitoring reports and their reviews be documented and maintained?**

-

### - — 9. Implement the Information System Activity Review and Audit Process

Not assessed

**Progress:** To do

Activate the necessary review process.

Begin auditing and logging activity.

**What mechanisms will be implemented to assess the effectiveness of the review process (measures)?**

-

**What is the plan to revise the review process when needed?**

-

### - — 1. Select a Security Official to be Assigned Responsibility for HIPAA Security

Not assessed

**Progress:** To do

Identify the individual who has final responsibility for security.

Select an individual who is able to assess effective security to serve as the point of contact for security policy, implementation, and monitoring.

**Does the security official have adequate access and communications with senior officials in the organization, such as executives, chief information officers, chief compliance officers, and in-house counsel?**

-

**Who in the organization is authorized to accept risks from systems on behalf of the organization?**

-

### - — 2. Assign and Document the Individual's Responsibility

Not assessed

**Progress:** To do

Document the assignment to one individual's responsibilities in a job description.

Communicate this assigned role to the entire organization.

**Is there a complete job description that accurately reflects assigned security duties and responsibilities?**

-

**Have the staff members in the organization been notified as to whom to call in the event of a security problem?**

-

### - — 1. Implement Policies and Procedures for Authorization and/or Supervision

Not assessed

**Progress:** To do

Implement procedures for the authorization and/or supervision of workforce members who work with ePHI or in locations where it might be accessed.

**Have chains of command and lines of authority been established?**

-

**Have staff members been made aware of the identity and roles of their supervisors?**
-

### - — Implementation Specification (Addressable)

Not assessed

**Progress:** To do

Implement procedures for the authorization and/or supervision of workforce members who work with ePHI or in locations where it might be accessed.

### - — 2. Establish Clear Job Descriptions and Responsibilities

Not assessed

**Progress:** To do

Define roles and responsibilities for all job functions.

Assign appropriate levels of security oversight, training, and access.

Identify in writing who has the business need and who has been granted permission to view, alter, retrieve, and store ePHI and at what times, under what circumstances, and for what purposes.

**Are there written job descriptions that are correlated with appropriate levels of access to ePHI?**
-

**Are these job descriptions reviewed and updated on a regular basis?**
-

**Have staff members been provided copies of their job descriptions and informed of the access granted to them, as well as the conditions by which this access can be used?**
-

### - — 3. Establish Criteria and Procedures for Hiring and Assigning Tasks

Not assessed

**Progress:** To do

Ensure that staff members have the necessary knowledge, skills, and abilities to fulfill particular roles (e.g., positions involving access to and use of sensitive information).

Ensure that these requirements are included as part of the personnel hiring process.

**Have the qualifications of candidates for specific positions been checked against the job description?**
-

**Have determinations been made that candidates for specific positions are able to perform the tasks of those positions?**
-

### - — 4. Establish a Workforce Clearance Procedure

Not assessed

**Progress:** To do

Implement procedures to determine that the access of a workforce member to ePHI is appropriate.

Implement appropriate screening of persons who will have access to ePHI.

Implement a procedure for obtaining clearance from appropriate offices or individuals where access is provided or terminated.

**Is there an implementation strategy that supports the designated access authorities?**
-

**Are applicants' employment and educational references checked, if reasonable and appropriate?**
-

**Have background checks been completed, if reasonable and appropriate?**
-

**Are there procedures for determining that the appropriate workforce members have access to the necessary information?**
-

**Do procedures exist for obtaining appropriate sign-offs to grant or terminate access to ePHI?**
-

**Have clearance and supervision procedures been developed for non-US based workforce members that are applicable to their location?**
-

### - — Implementation Specification (Addressable)

Not assessed

**Progress:** To do

Implement procedures to determine that the access of a workforce member to ePHI is appropriate.

### - — 5. Establish Termination Procedures

Partially compliant

**Progress:** In progress

Implement procedures for terminating access to ePHI when the employment of or other arrangement with a workforce member ends or as required by determinations made as specified in §164.308(a)(3)(ii)(B).

Develop a standard set of procedures that should be followed to recover access control devices (e.g., identification badges, keys, access cards) when employment ends.

Deactivate computer access accounts (e.g., disable user IDs and passwords) and facility access (e.g., change facility security codes/ PINs).

**Are there separate procedures for voluntary termination (e.g., retirement, promotion, transfer, change of employment) versus involuntary termination (e.g., termination for cause, reduction in force, involuntary transfer, criminal or disciplinary actions), if reasonable and appropriate?**
No

**Is there a standard checklist for all action items that should be completed when a workforce member leaves (e.g., return of all access devices, deactivation of logon accounts [including remote access], and delivery of any needed data solely under the employee's control)?**
No

**Do other organizations need to be notified to deactivate accounts that the workforce member had access to in the performance of their employment duties?**
N/A

**"Observation":** The termination procedure was tested using Jeevan Smith (TERM-2026-0301) on October 19, 2026. Entra ID account disablement, session revocation, and application-role removal were completed. However, the federated Keycloak account remained enabled until manually disabled and verified.

The existing manual termination control is operational, but standardized offboarding documentation and automated Keycloak deprovisioning require further improvement. Remediation is tracked through R02 and planned control CAN-CTRL-JML-002.

Finding: Incomplete Federated Account Deprovisioning

During Jeevan Smith's termination test (TERM-2026-0301) on October 19, 2026, the Microsoft Entra ID account was disabled, sign-in sessions were revoked, and the Billing application role was removed.

However, testing at 18:25 UTC showed that the federated Keycloak account remained enabled after the Entra ID termination actions. The Keycloak account was subsequently disabled manually and verified at approximately 18:28 UTC.

This identifies a gap in automated account deprovisioning between Entra ID and Keycloak. No active Keycloak sessions or unauthorized EHR access were observed during this test.

Existing control: CAN-CTRL-JML-001 – Manual Workforce Termination and Access Revocation.

Recommendation: Implement automated Keycloak deprovisioning, session revocation, reconciliation, and alerting. Validate effec-

tiveness through additional termination testing.

Related risk: R02 – Incomplete Leaver Deprovisioning.

Planned remediation: CAN-CTRL-JML-002 – Automated Keycloak Leaver Deprovisioning.

Finding status: Open – Remediation pending.

"Evidences": Jeevan Smith -Leaver Access Revocation Evidence

"Applied controls": Workforce Termination and Access Revocation

### - — Implementation Specification (Addressable)

Not assessed

**Progress:** To do

Implement procedures for terminating access to ePHI when the employment of or other arrangement with a workforce member ends or as required by determinations made as specified in §164.308(a)(3)(ii)(B).

### - — 1. Isolate Healthcare Clearinghouse Functions

Not assessed

**Progress:** To do

If a healthcare clearinghouse is part of a larger organization, the clearinghouse must implement policies and procedures that protect the ePHI of the clearinghouse from unauthorized access by the larger organization.

Determine whether a component of the regulated entity constitutes a healthcare clearinghouse under the HIPAA Security Rule.

If no clearinghouse functions exist, document this finding. If a clearinghouse exists within the organization, implement procedures for access that are consistent with the HIPAA Privacy Rule.

**If healthcare clearinghouse functions are performed, are policies and procedures implemented to protect ePHI from the other functions of the larger organization?**

-

**Does the healthcare clearinghouse share hardware or software with a larger organization of which it is a part?**

-

**Does the healthcare clearinghouse share staff or physical space with staff from a larger organization?**

-

**Has a separate network or subsystem been established for the healthcare clearinghouse, if reasonable and appropriate?**

-

**Has staff of the healthcare clearinghouse been trained to safeguard ePHI from disclosure to the larger organization, if required for compliance with the HIPAA Privacy Rule?**

-

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

If a healthcare clearinghouse is part of a larger organization, the clearinghouse must implement policies and procedures that protect the ePHI of the clearinghouse from unauthorized access by the larger organization.

### - — 2. Implement Policies and Procedures for Authorizing Access

Not assessed

**Progress:** To do

Implement policies and procedures for granting access to ePHI, such as through access to a workstation, transaction, program, process, or other mechanism.

Decide and document procedures for how access to ePHI will be granted to workforce members within the organization.

Select the basis for restricting access to ePHI.

Select an access control method (e.g., identity-based, role-based, or other reasonable and appropriate means of access.)

Decide and document how access to ePHI will be granted for privileged functions.

Ensure that there is a list of personnel with authority to approve user requests to access ePHI and systems with ePHI.

Identify authorized users with access to ePHI, including data owners and data custodians.

Consider whether multiple access control methods are needed to protect ePHI according to the results of the risk assessment.

Determine whether direct access to ePHI will ever be appropriate for individuals external to the organization (e.g., business partners or patients seeking access to their own ePHI).

**Have appropriate authorization and clearance procedures, as specified in Workforce Security (§ 164.308(a)(3)), been performed prior to granting access?**

-

**Do the organization's systems have the capacity to set access controls?**

-

**Are there documented job descriptions that accurately reflect assigned duties and responsibilities and enforce segregation of duties?**

-

**Has the organization documented procedures that specify how authorized personnel will be granted access to ePHI?**

-

**Does the organization grant remote access to ePHI?**

-

**What methods of access control are used (e.g., identity-based, role-based, location-based, or a combination) to protect ePHI?**

-

**Are there additional access control requirements for users who will be accessing privileged functions?**

-

**Have organizational personnel been explicitly authorized to approve user requests to access ePHI and/or systems with ePHI?**

-

### - — Implementation Specification (Addressable)

Not assessed

**Progress:** To do

Implement policies and procedures for granting access to ePHI, such as through access to a workstation, transaction, program, process, or other mechanism.

### - — 3. Implement Policies and Procedures for Access Establishment and Modification

Not assessed

**Progress:** To do

Implement policies and procedures that – based on the covered entity or business associate's access authorization policies – establish, document, review, and modify a user's right of access to a workstation, transaction, program, or process.

Establish standards for granting access to ePHI.

Provide formal authorization from the appropriate authority before granting access to ePHI.

Regularly review personnel access to ePHI to ensure that access is still authorized and needed.

Modify personnel access to ePHI, as needed, based on review activities.

**Are duties separated such that only the minimum necessary ePHI is made available to each workforce member based on their job requirements?**

-

**Are access decisions justified, approved, logged, and retained?**

-

**Is personnel access to ePHI regularly reviewed to ensure that access is still authorized and needed?**

-

**Are activities that review access to ePHI logged and retained, including decisions that arise from review activities?**

-

**Are decisions related to the establishment and modification of workforce member authorization to access ePHI documented?**

-

### - — Implementation Specification (Addressable)

Not assessed

**Progress:** To do

Implement policies and procedures that – based on the covered entity or business associate's access authorization policies – establish, document, review, and modify a user's right of access to a workstation, transaction, program, or process.

### - — 4. Evaluate Existing Security Measures Related to Access Controls

Not assessed

**Progress:** To do

Evaluate the security features of access controls that are already in place or those of any planned for implementation, as appropriate.

Determine whether these security features involve alignment with other existing management, operational, and technical controls, such as policy standards, personnel procedures, the maintenance and review of audit trails, the identification and authentication of users, and physical access controls.

**Are there policies and procedures related to the security of access controls?**

-

**If so, are they updated regularly?**

-

**Are authentication mechanisms used to verify the identity of those accessing systems protected from inappropriate manipulation?**

-

**Does management regularly review the list of access authorizations, including remote access authorizations, to verify that the list is accurate and has not been inappropriately altered?**

-

### - — 1. Conduct a Training Needs Assessment

Not assessed

**Progress:** To do

Determine the training needs of the organization.

Interview and involve key personnel in assessing security training needs.

Use feedback and analysis of past events to help determine training needs

Review organizational behavior issues, past incidents, and/or breaches to determine what training is missing or needs reinforcement, improvement, or periodic reminders.

**What awareness, training, and education programs are needed?**

-

**Which are required?**

-

**Is the organization monitoring current threats to determine possible areas of training needs?**

-

**Are there current, relevant threats (e.g., phishing, ransomware) about which personnel need training?**

-

**Do workforce members need training on any particular organization devices (e.g., medical IoT) or technology that pose a risk to ePHI?**

-

**What is the current status regarding how these needs are being addressed (e.g., how well are current efforts working)?**

-

**Where are the gaps between the needs and what is being done (e.g., what more needs to be done)?**

-

**What are the training priorities in terms of content and audience?**

-

### - — 2. Develop and Approve a Training Strategy and a Plan

Not assessed

**Progress:** To do

Address the specific HIPAA policies that require security awareness and training in the security awareness and training program.

Set organizational expectations for protecting ePHI.

In the security awareness and training program, outline the program's scope, goals, target audiences, learning objectives, deployment methods, and evaluation and measurement techniques, as well as the frequency of training

**Is there a procedure in place to ensure that everyone in the organization receives security awareness training, including teleworkers and remote personnel?**

-

**What type of security training is needed to address specific technical topics based on job responsibility?**

-

**When should training be scheduled to ensure that compliance deadlines are met?**

-

**Has the organization considered the training needs of non-employees (e.g., contractors, interns)?**

-

**Is there a need to implement information security training tailored to individual roles?**

-

### - — 3. Protection from Malicious Software, Login Monitoring, and Password Management

Not assessed

**Progress:** To do

As reasonable and appropriate, train workforce members regarding procedures for:

Incorporate information concerning workforce members' roles and responsibilities in implementing these implementation specifications into training and awareness efforts.

**Do workforce members know the importance of the timely application of system patches to protect against malicious software and the exploitation of vulnerabilities?**

-

**Are workforce members aware that login attempts may be monitored?**

-

**Do workforce members who monitor login attempts know to whom to report discrepancies?**

-

**Do workforce members understand their roles and responsibilities in selecting a password of appropriate strength, safeguarding their password, and changing a password when it has been compromised or is suspected of being compromised?**

-

**Are there policies in place that prohibit workforce members from sharing passwords with others?**

-

### - — Implementation Specification (Protection from Malicious Software)

Not assessed

**Progress:** To do

As reasonable and appropriate, train workforce members regarding procedures for:

### - — Implementation Specification (Log-in Monitoring)

Not assessed

**Progress:** To do

As reasonable and appropriate, train workforce members regarding procedures for:

### - — Implementation Specification (Password Management)

Not assessed

**Progress:** To do

As reasonable and appropriate, train workforce members regarding procedures for:

### - — 4. Develop Appropriate Awareness and Training Content, Materials, and Methods

Not assessed

**Progress:** To do

Select topics to be included in the training materials, and consider current and relevant topics (e.g., phishing, email security) for the protection of ePHI.

Incorporate new information from email advisories, online IT security daily news websites, and periodicals, as reasonable and appropriate.

Consider using a variety of media and avenues according to what is appropriate for the organization based on workforce size, location, level of education, and other factors.

Training should be an ongoing, evolving process in response to environmental and operational changes that affect the security of ePHI.

**Are the topics selected for training and awareness the most relevant to the threats, vulnerabilities, and risks identified during the risk assessment?**

-

**Does the organization periodically review the topics covered in training and awareness in light of updates to the risk assessment and current threats?**

-

**Have workforce members received a copy of and do they have ready access to the organization's security procedures and policies?**

-

**Do workforce members know whom to contact and how to handle a security incident?**

-

**Do workforce members understand the consequences of noncompliance with the stated security policies?**

-

**Do workforce members who travel, telework, or work remotely know how to handle physical laptop security issues and information security issues?**

-

**Has the regulated entity researched available training resources?**

-

**Is dedicated training staff available for the delivery of security training?**

-

**If not, who will deliver the training?**

-

**What is the security training budget?**

-

### - — 5. Implement the Training

Not assessed

**Progress:** To do

Schedule and conduct the training outlined in the strategy and plan.

Implement any reasonable technique to disseminate the security messages in an organization, including newsletters, screensavers, video recordings, email messages, teleconferencing sessions, staff meetings, and computer-based training.

**Have all workforce members received adequate training to fulfill their security responsibilities?**

-

**Are there sanctions if workforce members do not complete the required training?**

-

### - — 6. Implement Security Reminders

Not assessed

**Progress:** To do

Implement periodic security updates.

Provide periodic security updates to staff, business associates, and contractors.

Consider the benefits of ongoing communication with staff (e.g., emails, newsletters) on training topics to achieve HIPAA compliance and protect ePHI.

**What methods are available or already in use to make or keep workforce members aware of security (e.g., posters, booklets, anti-phishing training)?**

-

**Is the organization making use of existing resources (e.g., from the 405(d) program or other resources listed in Appendix F) to remind staff of important security topics?**

-

**Is security refresher training performed on a periodic basis (e.g., annually)?**

-

**Is security awareness discussed with all new hires?**

-

**Are security topics reinforced during routine staff meetings?**

-

### - — Implementation Specification (Addressable)

Not assessed

**Progress:** To do

Implement periodic security updates.

### - — 7. Monitor and Evaluate the Training Plan

Not assessed

**Progress:** To do

Keep the security awareness and training program current.

Solicit trainee feedback to determine whether the training and awareness are successfully reaching the intended audience.

Conduct training whenever changes occur in the technology and practices as appropriate.

Monitor the training program implementation to ensure that all workforce members participate.

Implement corrective actions when problems arise.

**Are the workforce members' training and professional development programs documented and monitored, if reasonable and appropriate?**

-

**How are new workforce members trained on security?**

-

**Are new non-employees (e.g., contractors, interns) trained on security?**

-

### - — 1. Determine the Goals of Incident Response

Not assessed

**Progress:** To do

Gain an understanding as to what constitutes a true security incident. Under the HIPAA Security Rule, a security incident is the attempted or successful unauthorized access, use, disclosure, modification, or destruction of information or interference with system operations in an information system (45 CFR § 164.304).

Ensure that the incident response program covers all parts of the organization in which ePHI is created, stored, processed, or transmitted.

Determine how the organization will respond to a security incident.

Establish a reporting mechanism and a process to coordinate responses to the security incident.

Provide direct technical assistance, advise vendors to address product-related problems, and provide liaisons to legal and criminal investigative groups as needed.

**Has the HIPAA-required security risk assessment resulted in a list of potential physical or technological events that could lead to a breach of security?**

-

**Is there a procedure in place for reporting and handling incidents?**

-

**Has an analysis been conducted that relates reasonably anticipated organizational threats (that could result in a security incident) to the methods that would be used for mitigation?**

-

**Have the key functions of the organization been prioritized to determine what would need to be restored first in the event of a disruption?**

-

### - — 2. Develop and Deploy an Incident Response Team or Other Reasonable and Appropriate Response Mechanism

Not assessed

**Progress:** To do

Determine whether the size, scope, mission, and other aspects of the organization justify the reasonableness and appropriateness of maintaining a standing incident response team.

Identify appropriate individuals to be part of a formal incident response team if the organization has determined that implementing an incident response team is reasonable and appropriate.

Consider assigning secondary personnel to be part of the incident response team in the event that primary personnel are unavailable.

**Do members of the team have adequate knowledge of the organization's hardware and software?**

-

**Do members of the team have the authority to speak for the organization to the media, law enforcement, and clients or business partners?**

-

**Has the incident response team received appropriate training in incident response activities?**

-

### - — 3. Develop and Implement Policy and Procedures to Respond to and Report Security Incidents

Not assessed

**Progress:** To do

Identify and respond to suspected or known security incidents; mitigate, to the extent practicable, harmful effects of security incidents that are known to the covered entity or business associate; and document security incidents and their outcomes.

Ensure that an organizational incident response policy is in place that addresses all parts of the organization in which ePHI is created, stored, processed, or transmitted.

Document incident response procedures that can provide a single point of reference to guide the day-to-day operations of the incident response team.

Review incident response procedures with staff who have roles and responsibilities related to incident response; solicit suggestions for improvements; and make changes to reflect input if reasonable and appropriate.

Consider conducting tests of the incident response plan.

Update the procedures as required based on changing organizational needs.

**Has the organization determined that maintaining a staffed security incident hotline would be reasonable and appropriate?**
-

**Has the organization developed processes for documenting and tracking incidents?**
-

**Has the organization determined reasonable and appropriate mitigation options for security incidents?**
-

**Has the organization developed standardized incident report templates to record necessary information related to incidents?**
-

**Has the organization determined that information captured in the reporting templates is reasonable and appropriate to investigate an incident?**
-

**Has the organization determined the conditions under which information related to a security breach will be disclosed to the media?**
-

**Have appropriate (internal and external) persons who should be informed of a security breach been identified?**
-

**Has a contact information list been prepared?**
-

**Has a written incident response plan been developed and provided to the incident response team?**
-

**Has the incident response plan been tested?**
-

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

Identify and respond to suspected or known security incidents; mitigate, to the extent practicable, harmful effects of security incidents that are known to the covered entity or business associate; and document security incidents and their outcomes.

### - — 4. Incorporate Post-Incident Analysis into Updates and Revisions

Not assessed

**Progress:** To do

Measure effectiveness and update security incident response procedures to reflect lessons learned, and identify actions to take that will improve security controls after a security incident.

Incidents caused by or influenced by known risks should feed back into the risk assessment process for a reevaluation of impact and/or likelihood.

Remediation and corrective action plans that arise from incidents should serve as input to the risk assessment/management process.

**Has the organization analyzed records (e.g., log files, malware) to understand the nature, extent, and scope of the incident?**
-

**Does the organization reassess risk to ePHI based on findings from this analysis?**
-

**Does the incident response team keep adequate documentation of security incidents and their outcomes, which may include what weaknesses were exploited and how access to the information was gained?**
-

**Do records reflect the new contacts and resources identified for responding to an incident?**
-

**Does the organization consider whether current procedures were adequate for responding to a particular security incident?**
-

### - — 1. Develop a Contingency Planning Policy

Not assessed

**Progress:** To do

Define the organization's overall contingency objectives.

Establish the organizational framework, roles, and responsibilities for this area.

Address scope, resource requirements, training, testing, plan maintenance, and backup requirements.

**What critical services must be provided within specified time frames?**
-

**Have cross-functional dependencies been identified to determine how a failure in one system may negatively impact another one?**
-

### - — 2. Conduct an Applications and Data Criticality Analysis

Not assessed

**Progress:** To do

Assess the relative criticality of specific applications and data in support of other Contingency Plan components.

Identify the activities and material involving ePHI that are critical to business operations.

Identify the critical services or operations and the manual and automated processes that support them involving ePHI.

Determine the amount of time that the organization can tolerate disruptions to these operations, materials, or services (e.g., due to power outages).

Evaluate the current and available levels of redundancy and geographic distribution of any storage service providers to identify risks to service availability and determine restoration times.

Consider whether any vendor/service provider arrangements are critical to operations and address them as appropriate to ensure availability and reliability.

Establish cost-effective strategies for recovering these critical services or processes.

**What hardware, software, and personnel are critical to daily operations?**
-

**What is the impact on desired service levels if these critical assets are not available?**
-

**What, if any, support is provided by external providers (e.g., cloud service providers, internet service providers, utilities, or contractors)?**
-

**What is the nature and degree of impact on the operation if any of the critical resources or service providers are not available?**
-

**Has the organization identified vendors or service providers that are critical to business operations?**
-

**Has the organization sufficiently addressed the availability and reliability of these services (e.g., via service level agreements, contracts)?**
-

### - — Implementation Specification (Addressable)

Not assessed

**Progress:** To do

Assess the relative criticality of specific applications and data in support of other Contingency Plan components.

### - — 3. Identify Preventive Measures

Not assessed

**Progress:** To do

Identify preventive measures for each defined scenario that could result in the loss of a critical service operation involving the use of ePHI.

Ensure that identified preventive measures are practical and feasible in terms of their applicability in a given environment.

**What alternatives for continuing operations of the organization are available in case of the loss of any critical function or resource?**
-

**What is the cost associated with the preventive measures that may be considered?**
-

**Are the preventive measures feasible (i.e., affordable and practical for the environment)?**
-

**What plans, procedures, or agreements need to be initiated to enable the implementation of the preventive measures if they are necessary?**
-

### - — 4. Develop Recovery Strategy

Not assessed

**Progress:** To do

Finalize the set of contingency procedures that should be invoked for all identified impacts, including emergency mode operation. The strategy must be adaptable to the existing operating environment and address allowable outage times and the associated priorities identified in Key Activity 2.

If part of the strategy depends on external organizations for support, ensure that formal agreements are in place with specific requirements stated.

**Have procedures related to recovery from emergency or disastrous events been documented?**
-

**Has a coordinator who manages, maintains, and updates the plan been designated?**
-

**Has an emergency call list been distributed to all workforce members?**
-

**Have recovery procedures been documented?**
-

**Has a determination been made regarding when the plan needs to be activated (e.g., anticipated duration of outage, tolerances for outage or loss of capability, impact on service delivery, etc.)?**
-

### - — 5. Data Backup Plan and Disaster Recovery Plan

Not assessed

**Progress:** To do

Establish and implement procedures to create and maintain retrievable exact copies of ePHI.

Establish (and implement as needed) procedures to restore any loss of data.

**Is there a formal, written contingency plan?**
-

**Does it address disaster recovery and data backup?**
-

**Does the disaster recovery plan address what data is to be restored and in what order?**
-

**Do data backup procedures exist that include all ePHI?**
-

**Is the frequency of backups appropriate for the environment?**
-

**Are responsibilities assigned to conduct backup activities?**
-

**Are data backup procedures documented and available to other staff?**
-

**Are backup logs reviewed and data restoration tests conducted to ensure the integrity of data backups?**
-

**Is at least one copy of the data backup stored offline to protect against corruption due to ransomware or other similar attacks?**
-

**Are backups or images of operating systems, devices, software, and configuration files necessary to support the confidentiality, integrity, and availability of ePHI included in the data backup plan?**
-

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

Establish and implement procedures to create and maintain retrievable exact copies of ePHI.

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

Establish (and implement as needed) procedures to restore any loss of data.

### - — 6. Develop and Implement an Emergency Mode Operation Plan

Not assessed

**Progress:** To do

Establish (and implement as needed) procedures to enable the continuation of critical business processes to protect the security of ePHI while operating in emergency mode.

“Emergency mode” operation involves only those critical business processes that must occur to protect the security of ePHI during and immediately after a crisis situation.

**Have procedures been developed to continue the critical functions identified in Key Activity 2?**
-

**If so, have those critical functions that also involve the use of ePHI been identified?**
-

**Would different staff, facilities, or systems be needed to perform those functions?**
-

**Has the security of ePHI in that alternative mode of operation been assured?**
-

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

Establish (and implement as needed) procedures to enable the continuation of critical business processes to protect the security of ePHI while operating in emergency mode.

### - — 7. Testing and Revision Procedure

Not assessed

**Progress:** To do

Implement procedures for the periodic testing and revision of contingency plans.

Test the contingency plan on a predefined cycle (stated in the policy developed under Key Activity 1), if reasonable and appropriate.

Train those with defined plan responsibilities in their roles.

If possible, involve external entities (e.g., vendors, alternative site or service providers) in testing exercises.

Make key decisions regarding how the testing is to occur (e.g., tabletop exercise versus staging a real operational scenario, including actual loss of capability).

Decide how to segment the type of testing based on the assessment of business impact and the acceptability of a sustained loss of service.

**How is the contingency plan to be tested?**
-

**Does testing lend itself to a phased approach?**
-

**Is it feasible to actually take down functions or services for the purposes of testing?**
-

**Has the organization conducted backup recovery testing to ensure that critical data can be recovered using existing data backups?**
-

**Does the backup recovery testing verify the ability to recover data and operations based on identified testing scenarios using actual tests (i.e., not tabletop exercises)?**
-

**Can testing be done during normal business hours or must it take place during off hours?**
-

**Have the tests included personnel with contingency planning responsibilities?**
-

**Have the results of each test been documented and any problems with the test reviewed and corrected?**
-

**If full testing is infeasible, has a tabletop scenario (e.g., a classroom-like exercise) been considered?**
-

**How frequently will the plan be tested (e.g., annually)?**
-

**When should the plan be revised?**
-

### - — Implementation Specification (Addressable)

Not assessed

**Progress:** To do

Implement procedures for the periodic testing and revision of contingency plans.

### - — 1. Determine Whether Internal or External Evaluation is Most Appropriate

Not assessed

**Progress:** To do

Decide whether the evaluation will be conducted with internal staff resources or external consultants.

Engage external expertise to assist the internal evaluation team where additional skills and expertise are determined to be reasonable and appropriate.

Use internal resources to supplement an external source of help because these internal resources can provide the best institutional knowledge and history of internal policies and practices.

**Which staff has the technical experience and expertise to evaluate the systems?**

-

**Are the evaluators sufficiently independent to provide objective reporting?**

-

**How much training will staff need on security-related technical and non-technical issues?**

-

**If an outside vendor is used, what factors should be considered when selecting the vendor, such as credentials and experience?**

-

**What is the budget for internal resources to assist with an evaluation?**

-

**What is the budget for external services to assist with an evaluation?**

-

### - — 2. Develop Standards and Measurements for Reviewing All Standards and Implementation Specifications of the Security Rule

Not assessed

**Progress:** To do

Develop and document organizational policies and procedures for conducting evaluation.

Once security controls have been implemented in response to the organization's risk assessment and management processes, periodically review these implemented security measures to ensure their continued effectiveness in protecting ePHI.

Consider determining any specific evaluation metrics and/or measurements to be captured during evaluation. Metrics and/or measurements can assist in tracking progress over time.

Use an evaluation strategy and tool that considers all elements of the HIPAA Security Rule and can be tracked, such as a questionnaire or checklist.

Implement tools that can provide reports on the level of compliance, integration, or maturity of a particular security safeguard deployed to protect ePHI.

If available, consider engaging corporate, legal, or regulatory compliance staff when conducting the analysis.

Leverage any existing reports or documentation that may already be prepared by the organization addressing the compliance, integration, or maturity of a particular security safeguard deployed to protect ePHI.

**Has the organization documented policies and procedures for conducting the evaluation of security controls?**

-

**Have management, operational, and technical issues been considered?**

-

**Do the elements of each evaluation procedure (e.g., questions, statements, or other components) address individual, measurable security safeguards for ePHI?**

-

**Has the organization developed evaluation procedures that capture any desired metrics or measurements?**

-

**Has the organization determined that the procedure must be tested in a few areas or systems?**
-

**Does the evaluation tool consider all standards and implementation specifications of the HIPAA Security Rule?**
-

**Does the evaluation tool address the protection of ePHI that is collected, used, or disclosed?**
-

## - — 3. Conduct Evaluation

Not assessed

**Progress:** To do

Determine in advance what departments and/or staff will participate in the evaluation.

Determine what constitutes an environmental or operational change that affects the security of ePHI.

Determine when evaluations are conducted in response to an environmental or operational change that affects the security of ePHI (e.g., prior to the change, contemporaneous with the change, after the change).

Secure management support for the evaluation process to ensure participation.

Collect and document all needed information. Collection methods may include the use of interviews, surveys, and the outputs of automated tools, such as access control auditing tools, system logs, and the results of penetration testing.

Conduct penetration testing (where testers attempt to compromise system security for the sole purpose of testing the effectiveness of security controls), if reasonable and appropriate.

Evaluation may include reviewing organizational policies and procedures, assessing the implementation of security controls, collecting evidence of security control implementation, and performing physical walk- throughs.

**If available, have staff members with knowledge of IT security been consulted and included in the evaluation team?**
-

**Are appropriate personnel notified of planned environmental or operational changes that could affect the security of ePHI?**
-

**Is a change management process in place that includes identification and communication of environmental and operational changes that could affect the security of ePHI?**
-

**If penetration testing has been determined to be reasonable and appropriate, has specifically worded, written approval from senior management been received for any planned penetration testing?**
-

**Has the process been formally communicated to those who have been assigned roles and responsibilities in the evaluation process?**
-

**Has the organization explored the use of automated tools to support the evaluation process?**
-

## - — 4. Document Results

Not assessed

**Progress:** To do

Document each evaluation finding, as well as remediation options, recommendations, and decisions.

Document known gaps between identified risks, mitigating security controls, and any acceptance of risk, including justification.

Develop security program priorities, and establish targets for continuous improvement.

Utilize the results of evaluations to inform impactful security changes to protect ePHI.

Communicate evaluation results, metrics, and/or measurements to relevant organizational personnel.

**Does the process support the development of security recommendations?**

-

**When determining how best to display evaluation results, have written reports that highlight key findings and recommendations been considered?**

-

**If a written final report is to be circulated among key staff, have steps been taken to ensure that it is made available only to those persons designated to receive it?**

-

**Does the organization use evaluation results to enhance the protection of ePHI rather than for the sake of compliance?**

-

### - — 5. Repeat Evaluations Periodically

Not assessed

**Progress:** To do

Establish the frequency of evaluations, and consider the sensitivity of the ePHI controlled by the organization as well as the organization's size, complexity, and environmental and/or operational changes (e.g., other relevant laws or accreditation requirements).

In addition to periodic reevaluations, consider repeating evaluations when environmental and operational changes that affect the security of ePHI are made to the organization (e.g., if new technology is adopted or if there are newly recognized risks to the security of ePHI).

**Do security policies specify that evaluations will be repeated when environmental and operational changes are made that affect the security of ePHI?**

-

**Do policies on the frequency of security evaluations reflect any and all relevant federal or state laws that bear on environmental or operational changes affecting the security of ePHI?**

-

**Has the organization explored the use of automated tools to support periodic evaluations?**

-

### - — 1. Identify Entities that are Business Associates Under the HIPAA Security Rule

Not assessed

**Progress:** To do

Identify the individual or department who will be responsible for coordinating the execution of business associate agreements or other arrangements.

Reevaluate the list of business associates to determine who has access to ePHI in order to assess whether the list is complete and current.

Identify systems covered by the contract/agreement.

Business associates must have a BAA in place with each of their subcontractor business associates. Subcontractor business associates are also directly liable for their own Security Rule violations.

**Does each written and executed BAA contain sufficient language to ensure that ePHI and any other required information types will be protected?**

-

**Have all organizations or vendors that provide a service or function on behalf of the organization been identified?**

-

**Such services may include:**

-

**Have outsourced functions that involve the use of ePHI been considered?**

-

**Such functions may include:**

-

### - — 2. Establish a Process for Measuring Contract Performance and Terminating the Contract if Security Requirements Are Not Being Met

Not assessed

**Progress:** To do

Maintain clear lines of communication between covered entities and business associates regarding the protection of ePHI as per the BAA or contract.

Establish criteria for measuring contract performance.

**What is the service being performed?**

-

**What is the expected outcome?**

-

**Is there a process for reporting security incidents related to the agreement?**

-

**Are additional assurances of protections for ePHI from the business associate necessary?**

-

**If so, where will such additional assurances be documented (e.g., in the BAA, service-level agreement, or other documentation), and how will they be met (e.g., providing documentation of implemented safeguards, audits, certifications)?**

-

### - — 3. Written Contract or Other Arrangement

Not assessed

**Progress:** To do

Document the satisfactory assurances required by this standard through a written contract or other arrangement with the business associate that meets the applicable requirements of §164.314(a). Readers may find useful resources in Appendix F, including OCR BAA guidance and/or templates that include applicable language.

Execute new or update existing agreements or arrangements as appropriate.

Identify roles and responsibilities.

Include security requirements in business associate contracts and agreements to address the confidentiality, integrity, and availability of ePHI.

Specify any training requirements associated with the contract/agreement or arrangement, if reasonable and appropriate.

**Who is responsible for coordinating and preparing the final agreement or arrangement?**

-

**Does the agreement or arrangement specify how information is to be transmitted to and from the business associate?**

-

**Have security controls been specified for the business associate?**

-

**Are clear responsibilities identified and established regarding potentially overlapping HIPAA obligations (e.g., if hosting ePHI in the cloud, will the CE, BA, or both address encryption)?**

-

**Have appropriate organizational personnel been trained in the process of initiating and maintaining a business associate agreement (BAA)?**

-

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

Document the satisfactory assurances required by this standard through a written contract or other arrangement with the business associate that meets the applicable requirements of §164.314(a). Readers may find useful resources in Appendix F, including OCR BAA guidance and/or templates that include applicable language.

### - — 1. Conduct an Analysis of Existing Physical Security Vulnerabilities

Not assessed

**Progress:** To do

Inventory facilities and identify shortfalls and/or vulnerabilities in current physical security capabilities.

Assign degrees of significance to each vulnerability identified and ensure that proper access is allowed.

Determine which types of facilities require access controls to safeguard ePHI, such as:

**If reasonable and appropriate, do non-public areas have locks and cameras?**

-

**Are computing devices protected from public access or viewing?**

-

**Are entrances and exits that lead to locations with ePHI secured?**

-

**Do policies and procedures already exist regarding access to and use of facilities and equipment?**

-

**Are there possible natural or human-made disasters that could happen in the environment?**

-

**Do normal physical protections exist (e.g., locks on doors, windows, and other means of preventing unauthorized access)?**

-

**Are network wiring cables protected and not exposed to unauthorized personnel?**

-

**Is there a list of workforce members who can access the facility after hours via the use of keys, badge access, and knowledge of the security or alarm system?**

-

### - — 2. Identify Corrective Measures

Not assessed

**Progress:** To do

Identify and assign responsibility for the measures and activities necessary to correct deficiencies, and ensure that proper physical access is allowed.

Develop and deploy policies and procedures to ensure that repairs, upgrades, and/or modifications are made to the appropriate physical areas of the facility while ensuring that proper access is allowed.

**Who is responsible for security?**

-

**Is a workforce member other than the security official responsible for facility/physical security?**

-

**Are facility access control policies and procedures already in place?**

-

**Do they need to be revised?**

-

**What training will be needed for workforce members to understand the policies and procedures?**

-

**How will decisions and actions be documented?**

-

**Is a property owner or external party (e.g., cloud service provider) required to make physical changes to meet the requirements?**

-

### - — 3. Develop a Facility Security Plan

Not assessed

**Progress:** To do

Implement policies and procedures to safeguard the facility and the equipment therein from unauthorized physical access, tampering, and theft.

Implement appropriate measures to provide physical security protection for ePHI in a regulated entity's possession.

Include documentation of the facility inventory, physical maintenance records, and a history of changes, upgrades, and other modifications.

Identify points of access to the facility and existing security controls.

**Is there an inventory of facilities and existing security practices?**

-

**What are the current procedures for securing the facilities (e.g., exterior, interior, equipment, access controls, maintenance records)?**

-

**Is a workforce member other than the security official responsible for the facility plan?**

-

**Is there a contingency plan already in place, under revision, or under development?**

-

### - — Implementation Specification (Addressable)

Not assessed

**Progress:** To do

Implement policies and procedures to safeguard the facility and the equipment therein from unauthorized physical access, tampering, and theft.

### - — 4. Develop Access Control and Validation Procedures

Not assessed

**Progress:** To do

Implement procedures to control and validate a person's access to facilities based on their role or function, including visitor control and control of access to software programs for testing and revision.

Implement procedures to provide facility access to authorized personnel and visitors and exclude unauthorized persons.

**What are the policies and procedures in place for controlling access by staff, contractors, visitors, and probationary workforce members?**

-

**Do the procedures identify individuals, roles, or job functions that are authorized to access software programs for testing and revision?**

-

**How many access points exist in each facility?**

-

**Is there an inventory?**

-

**Is monitoring equipment necessary?**

-

**Is there a periodic review of personnel with physical access?**

-

### - — Implementation Specification (Addressable)

Not assessed

**Progress:** To do

Implement procedures to control and validate a person's access to facilities based on their role or function, including visitor control and control of access to software programs for testing and revision.

### - — 5. Establish Contingency Operations Procedures

Not assessed

**Progress:** To do

Establish (and implement as needed) procedures that allow facility access in support of the restoration of lost data under the Disaster Recovery Plan and Emergency Mode Operations Plan in the event of an emergency.

**Are there procedures to allow facility access while restoring lost data in the event of an emergency?**

-

**Who needs access to ePHI in the event of a disaster?**

-

**What is the backup plan for access to the facility and/or ePHI?**

-

**Who is responsible for the contingency plan for access to ePHI?**

-

**Who is responsible for implementing the contingency plan for access to ePHI in each department or unit?**

-

**Will the contingency plan be appropriate in the event of all types of potential disasters (e.g., fire, flood, earthquake, etc.)?**

-

### - — Implementation Specification (Addressable)

Not assessed

**Progress:** To do

Establish (and implement as needed) procedures that allow facility access in support of the restoration of lost data under the Disaster Recovery Plan and Emergency Mode Operations Plan in the event of an emergency.

### - — 6. Maintain Maintenance Records

Not assessed

**Progress:** To do

Implement policies and procedures to document repairs and modifications to the physical components of a facility that are related to security (e.g., hardware, walls, doors, and locks).

**Are policies and procedures developed and implemented that specify how to document repairs and modifications to the physical components of a facility that are related to security?**

-

**Are records of repairs to hardware, walls, doors, and locks maintained?**

-

**Has responsibility for maintaining these records been assigned?**

-

### - — Implementation Specification (Addressable)

Not assessed

**Progress:** To do

Implement policies and procedures to document repairs and modifications to the physical components of a facility that are related to security (e.g., hardware, walls, doors, and locks).

### - — 1. Identify Workstation and Device Types and Functions or Uses

Not assessed

**Progress:** To do

Inventory workstations and devices that create, store, process or transmit ePHI. Be sure to consider the multitude of computing devices (e.g., medical equipment, medical IoT devices, tablets, smart phones, etc.).

Develop policies and procedures for each type of device and identify and accommodate their unique issues.

Classify devices based on the capabilities, connections, and allowable activities for each device used.

Determine the proper function and manner by which specific workstations or classes of workstations are permitted to access ePHI (e.g., applications permitting access to ePHI that are allowed on workstations used by a hospital's customer service call center or its radiology department).

**Do the policies and procedures identify devices that access ePHI and those that do not?**

-

**Is there an inventory of device types and locations in the organization?**

-

**Who is responsible for this inventory and its maintenance?**

-

**What tasks are commonly performed on a given device or type of device?**

-

**Are all types of computing devices used as workstations identified along with the use of these devices?**

-

**Are all devices that create, store, process, or transmit ePHI owned by the regulated entity?**

-

**Are some devices personally owned or owned by another party?**

-

**Has the organization considered the use of automation to manage device inventory?**

-

### - — 2. Identify the Expected Performance of Each Type of Workstation and Device

Not assessed

**Progress:** To do

Develop and document policies and procedures related to the proper use and performance of devices that create, store, process, or transmit ePHI.

**How are these devices used in day-to-day operations?**

-

**Which devices are involved in various work activities?**

-

**What are key operational risks that could result in a breach of security?**

-

**Do the policies and procedures address the use of these devices for any personal use?**

-

**Has the organization updated training and awareness content to include the proper use and performance of these devices?**

-

### - — 3. Analyze Physical Surroundings for Physical Attributes

Not assessed

**Progress:** To do

Ensure that any risks associated with a device's surroundings are known and analyzed for possible negative impacts.

Develop policies and procedures that will prevent or preclude the unauthorized access of unattended devices, limit the ability of unauthorized persons to view sensitive information, and dispose of sensitive information as needed.

**Do the policies and procedures specify where to place devices to only allow viewing by authorized personnel?**

-

**Where are devices located?**

-

**Where does work on ePHI occur?**

-

**Are some devices stationary?**

-

**Are some devices mobile and leave the physical facility?**

-

**Is viewing by unauthorized individuals restricted or limited on these devices?**

-

**Do changes need to be made in the space configuration?**

-

**Do workforce members understand the security requirements for the data they use in their day-to-day jobs?**

-

**Are any computing components (e.g., servers, workstations, medical devices) kept in locations that put the confidentiality, integrity, and availability of ePHI at risk?**

-

### - — 1. Identify All Methods of Physical Access to Workstations and Devices

Not assessed

**Progress:** To do

Document the different ways that users access workstations and other devices that create, store, process, or transmit ePHI. Be sure to consider the multitude of computing devices (e.g., medical equipment, medical IoT devices, tablets, smart phones, etc.).

Consider any mobile devices that leave the physical facility as well as remote workers who access devices that create, store, process, or transmit ePHI.

**Is there an inventory of all current device locations?**

-

**Are any devices located in public areas?**

-

**Are laptops or other computing devices used as workstations to create, access, store, process, or transmit ePHI?**

-

### - — 2. Analyze the Risks Associated with Each Type of Access

Not assessed

**Progress:** To do

Determine which type of access identified in Key Activity 1 poses the greatest threat to the security of ePHI.

**Do any devices leave the facility?**

-

**Are any devices housed in areas that are more vulnerable to unauthorized use, theft, or viewing of the data they contain?**

-

**What are the options for modifying the current access configuration to protect ePHI?**

-

### - — 3. Identify and Implement Physical Safeguards for Workstations and Devices

Not assessed

**Progress:** To do

Implement physical safeguards and other security measures to minimize the possibility of inappropriate access to ePHI through computing devices.

If there are impediments to physically securing devices and/or the facilities where devices are located, additional safeguards should be considered, such as:

**Are physical safeguards implemented for all devices that access ePHI to restrict access to authorized users?**

-

**Are devices and other tools used in the provisioning of treatment, payment and operations protected from unauthorized access, viewing, modification, and/or theft within mobile healthcare environments?**

-

**What safeguards are in place,(e.g., locked doors, screen barriers, cameras, guards)?**

-

**Are additional physical safeguards needed to protect devices with ePHI?**

-

**Do any devices need to be relocated to enhance physical security?**

-

**Are safeguards such as anti-theft devices, physical privacy screens, or other procedures used to help prevent unauthorized audio and video recording**

-

**Have workforce members been trained on security?**

-

**Are some devices not owned by the organization?**

-

**Do these ownership considerations preclude the use of any physical security controls on the device?**

-

**Do the policies and procedures specify the use of additional security measures to protect devices with ePHI, such as using privacy screens, enabling password-protected screen savers, or logging off the device?**

-

### - — 1. Implement Methods for the Final Disposal of ePHI

Not assessed

**Progress:** To do

Implement policies and procedures to address the final disposition of ePHI and/or the hardware or electronic media on which it is stored.

Determine and document the appropriate methods to dispose of hardware, software, and the data itself.

Ensure that ePHI is properly destroyed and cannot be recreated.

**What ePHI is created, stored, processed, and transmitted by the organization?**

-

**On what media is it located?**

-

**Is data stored on removable, reusable media (e.g., flash drives, Secure Digital (SD) memory cards)?**

-

**Are policies and procedures developed and implemented that address the disposal of ePHI and/or the hardware and media on which ePHI is stored?**

-

**Is there a process for destroying data on all media?**

-

**What are the options for disposing of data on hardware?**

-

**What are the costs?**

-

**Prior to disposal, have media and devices containing ePHI been sanitized in accordance with SP 800-88?**

-

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

Implement policies and procedures to address the final disposition of ePHI and/or the hardware or electronic media on which it is stored.

### - — 2. Develop and Implement Procedures for the Reuse of Electronic Media

Not assessed

**Progress:** To do

Implement procedures for the removal of ePHI from electronic media before the media become available for reuse.

Ensure that ePHI previously stored on any electronic media cannot be accessed and reused.

Identify removable media and their uses.

Ensure that ePHI is removed from reusable media before they are used to record new information.

**Do policies and procedures already exist regarding the reuse of electronic media (i.e., hardware and software)?**

-

**Have reused media been erased to the point where previous ePHI is neither readily available nor recoverable?**

-

**Is one individual and/or department responsible for coordinating the disposal of data and the reuse of the hardware and software?**

-

**Are workforce members appropriately trained on the security risks to ePHI when reusing software and hardware?**

-

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

Implement procedures for the removal of ePHI from electronic media before the media become available for reuse.

### - — 3. Maintain Accountability for Hardware and Electronic Media

Not assessed

**Progress:** To do

Maintain a record of the movements of hardware and electronic media and any person responsible for them.

Ensure that ePHI is not inadvertently released or shared with any unauthorized party.

Ensure that an individual is responsible for and records the receipt and removal of hardware and software with ePHI.

**Have policies and procedures been implemented that govern the receipt and removal of hardware and electronic media that contain ePHI into and out of a facility, and the movement of these items within the facility?**

-

**Has a process been implemented to maintain a record of the movements of and persons responsible for hardware and electronic media that contain ePHI?**

-

**Where is data stored (i.e., what type of media)?**

-

**What procedures already exist to track hardware and software within the organization (e.g., an enterprise inventory management system)?**

-

**If workforce members are allowed to remove electronic media that contain or may be used to access ePHI, do procedures exist to track the media externally?**

-

**Who is responsible for maintaining records of hardware and software?**

-

### - — Implementation Specification (Addressable)

Not assessed

**Progress:** To do

Maintain a record of the movements of hardware and electronic media and any person responsible for them.

### - — 4. Develop Data Backup and Storage Procedures

Not assessed

**Progress:** To do

Create a retrievable exact copy of ePHI, when needed, before movement of equipment.

Ensure that an exact retrievable copy of the data is retained and protected to maintain the integrity of ePHI during equipment relocation.

**Has a process been implemented to create a retrievable, exact copy of ePHI when needed and before the movement of equipment?**

-

**Are backup files maintained offsite to ensure data availability in the event that data is lost while transporting or moving electronic media that contain ePHI?**

-

**If data were to be unavailable while media are transported or moved for a period of time, what would the business impact be?**

-

### - — Implementation Specification (Addressable)

Not assessed

**Progress:** To do

Create a retrievable exact copy of ePHI, when needed, before movement of equipment.

### - — 1. Analyze Workloads and Operations to Identify the Access Needs of All Users

Not assessed

**Progress:** To do

Identify an approach for access control.

Consider all applications and systems containing ePHI that should only be available to authorized users, processes, and services.

Integrate these activities into the access granting and management process.

**Have all applications and systems with ePHI been identified?**

-

**What user roles are defined for those applications and systems?**

-

**Is access to systems containing ePHI only granted to authorized processes and services?**

-

**Where is the ePHI supporting those applications and systems currently housed (e.g., stand-alone computer, network storage, database)?**

-

**Are data and/or systems being accessed remotely?**

-

**Have access decisions been based on determinations from § 164.308(a)(4) Information Access Management?**

-

### - — 2. Identify Technical Access Control Capabilities

Not assessed

**Progress:** To do

Determine the access control capabilities of all systems with ePHI.

Determine whether network infrastructure can limit access to systems with ePHI (e.g., network segmentation).

Implement technical access controls to limit access to ePHI to only that which has been granted in accordance with the regulated entity's information access management policies and procedures (see 45 CFR 164.308(a)(4)).

**How are the systems accessed for viewing, modifying, or creating data?**

-

**Can identified technical access controls limit access to ePHI to only what is authorized in accordance with the regulated entity's information access management policies and procedures (see 45 CFR 164.308(a)(4))?**
-

### - — 3. Ensure that All System Users Have Been Assigned a Unique Identifier

Not assessed

**Progress:** To do

Assign a unique name and/or number for identifying and tracking user identity.

Ensure that system activity can be traced to a specific user.

Ensure that the necessary data is available in the system logs to support audit and other related business functions.

**How should the identifier be established (e.g., length and content)?**
-

**Should the identifier be self-selected, organizationally selected, or randomly generated?**
-

**Are logs associated with access events created?**
-

**Are these access logs regularly reviewed?**
-

**Can the unique user identifier be used to track user access to ePHI?**
-

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

Assign a unique name and/or number for identifying and tracking user identity.

### - — 4. Develop Access Control Policy and Procedures

Not assessed

**Progress:** To do

Establish a formal policy for access control that will guide the development of procedures.

Specify requirements for access control that are both feasible and cost-effective.

**Have rules of behavior been established and communicated to system users?**
-

**How will rules of behavior be enforced?**
-

### - — 5. Implement Access Control Procedures Using Selected Hardware and Software

Not assessed

**Progress:** To do

Implement the policy and procedures using existing or additional hardware or software solutions.

**Who will manage the access control procedures?**
-

**Are current users trained in access control management?**
-

**Will user training be needed to implement access control procedures?**
-

**Do the medical devices in use by the organization support user authentication?**
-

**Are there processes in place to manage this authentication?**
-

### - — 6. Review and Update Access for Users and Processes

Not assessed

**Progress:** To do

Enforce the policy and procedures as a matter of ongoing operations.

Determine whether any changes are needed for access control mechanisms.

Ensure that the modification of technical controls that affect a user's access to ePHI continue to limit access to ePHI to that which has been granted in accordance with the regulated entity's information access management policies and procedures (see 45 CFR 164.308(a)(4)).

Establish procedures for updating access when users require the following:

**Have new workforce members/users been given proper instructions for protecting data and systems?**
-

**What are the procedures for new employee/user access to data and systems?**
-

**Are there procedures for reviewing and, if appropriate, modifying access authorizations for existing users, services, and processes?**
-

**Do users and processes have the appropriate set of permissions to ePHI to which they were granted access and to the appropriate systems that create, store, process, or transmit ePHI?**
-

**Has the regulated entity considered the use of automation for reviewing the access needs of users and processes?**
-

### - — 7. Establish an Emergency Access Procedure

Not assessed

**Progress:** To do

Establish (and implement as needed) procedures for obtaining necessary electronic protected health information during an emergency.

Identify a method for supporting continuity of operations should the normal access procedures be disabled or unavailable due to system problems.

**Are there policies and procedures in place to provide appropriate access to ePHI in emergency situations?**
-

**When should the emergency access procedure be activated?**
-

**Who is authorized to make the decision?**
-

**Who has assigned roles in the process?**
-

**Will systems automatically default to settings and functionalities that will enable the emergency access procedure or will the mode be activated by the system administrator or other authorized individual?**
-

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

Establish (and implement as needed) procedures for obtaining necessary electronic protected health information during an emergency.

### - — 8. Automatic Logoff and Encryption and Decryption

Not assessed

**Progress:** To do

Consider whether the addressable implementation specifications of this standard are reasonable and appropriate:

**Are automatic logoff features available for any of the regulated entity's operating systems or other major applications?**

-

**If applications have been created or developed in-house, is it reasonable and appropriate to modify them to feature an automatic logoff capability?**

-

**What period of inactivity prior to automatic logoff is reasonable and appropriate for the regulated entity?**

-

**What encryption capabilities are available for the regulated entity's ePHI?**

-

**Is encryption appropriate for storing and maintaining ePHI (i.e., at rest)?**

-

**Based on the risk assessment, is encryption needed to effectively protect ePHI at rest from unauthorized access?**

-

**Is email encryption necessary for the organization to protect ePHI?**

-

**Are automated confidentiality statements needed for email leaving the organization?**

-

### - — Implementation Specification (Automatic Logoff)

Not assessed

**Progress:** To do

Consider whether the addressable implementation specifications of this standard are reasonable and appropriate:

### - — Implementation Specification (Encryption and Decryption)

Not assessed

**Progress:** To do

Consider whether the addressable implementation specifications of this standard are reasonable and appropriate:

### - — 9. Terminate Access if it is No Longer Required

Not assessed

**Progress:** To do

Ensure that access to ePHI is terminated if the access is no longer authorized.

Consider implementing a user recertification process to ensure that least privilege is enforced.

**Are rules being enforced to remove access by staff members who no longer have a need to know because they have changed assignments or have stopped working for the organization?**

-

**Does the organization revisit user access requirements regularly to ensure least privilege?**

-

### - — 1. Determine the Activities that Will Be Tracked or Audited

Not assessed

**Progress:** To do

Determine the appropriate scope of audit controls that will be necessary in information systems that contain or use ePHI based on the regulated entity's risk assessment and other organizational factors.

Determine what activities need to be captured using the results of the risk assessment and risk management processes.

**Where is ePHI at risk in the organization?**

-

**What systems, applications, or processes make ePHI vulnerable to unauthorized or inappropriate tampering, uses, or disclosures?**

-

**What activities will be audited (e.g., creating ePHI, accessing ePHI, modifying ePHI, transmitting ePHI, and/or deleting files or records that contain ePHI)?**

-

**What should the audit record include (e.g., user responsible for the activity; event type, date, or time)?**

-

**Are audit records generated for all systems/devices that create, store, process, or transmit ePHI?**

-

### - — 2. Select the Tools that Will Be Deployed for Auditing and System Activity Reviews

Not assessed

**Progress:** To do

Evaluate existing system capabilities and determine whether any changes or upgrades are necessary.

**What tools are in place?**

-

**What are the most appropriate monitoring tools for the organization (e.g., third party, freeware, or operating system-provided)?**

-

**Are changes/upgrades to information systems reasonable and appropriate?**

-

### - — 3. Develop and Deploy the Information System Activity Review/Audit Policy

Not assessed

**Progress:** To do

Document and communicate to the workforce the organization's decisions on audits and reviews.

**Who is responsible for the overall audit process and results?**

-

**How often will audits take place?**

-

**How often will audit results be analyzed?**

-

**What is the organization's sanction policy for employee violations?**

-

**Where will audit information reside (e.g., separate server)?**

-

### - — 4. Develop Appropriate Standard Operating Procedures

Not assessed

**Progress:** To do

Determine the types of audit trail data and monitoring procedures that will be needed to derive exception reports.

Determine the frequency of audit log reviews based on the risk assessment and risk management processes.

**How will exception reports or logs be reviewed?**

-

**Has the organization considered the use of automation to assist in the monitoring and review of system activity?**

-

**Are the organization's monitoring system activity and logs reviewed frequently enough to sufficiently protect ePHI?**

-

**Where will monitoring reports be filed and maintained?**
-

**Is there a formal process in place to address system misuse, abuse, and fraudulent activity?**
-

**How will managers and workforce members be notified, when appropriate, regarding suspect activity?**
-

### - — 5. Implement the Audit/System Activity Review Process

Not assessed

**Progress:** To do

Activate the necessary audit system.
Begin logging and auditing procedures.

**What mechanisms (e.g., metrics) will be implemented to assess the effectiveness of the audit process?**
-

**What is the plan to revise the audit process when needed?**
-

### - — 1. Identify All Users Who Have Been Authorized to Access ePHI

Not assessed

**Progress:** To do

Identify all approved users with the ability to alter or destroy ePHI, if reasonable and appropriate.

Address this Key Activity in conjunction with the identification of unauthorized sources in Key Activity 2.

**How are users authorized to access the information?**
-

**Is there a sound basis for why they need the access?**
-

**Have they been trained on how to use the information?**
-

**Is there an audit trail established for all accesses to the information?**
-

### - — 2. Identify Any Possible Unauthorized Sources that May Be Able to Intercept the Information and Modify It

Not assessed

**Progress:** To do

Identify scenarios that may result in modification to the ePHI by unauthorized sources (e.g., hackers, ransomware, insider threats, business competitors, user errors).

Conduct this activity as part of a risk analysis.

Consider how the organization will detect unauthorized modification to ePHI

**What are likely sources that could jeopardize information integrity?**
-

**What can be done to protect the integrity of the information when it is residing in a system (at rest)?**
-

**What procedures and policies can be established to decrease or prevent alteration of the information during transmission?**
-

**What options exist to detect the unauthorized modification of ePHI?**
-

### - — 3. Develop the Integrity Policy and Requirements

Not assessed

**Progress:** To do

Establish a formal written set of integrity requirements based on the results of the analysis completed in Key Activities 1 and 2.

**Have the requirements been discussed and agreed to by identified key personnel involved in the processes that are affected?**
-

**Have the requirements been documented?**
-

**Has a written policy been developed and communicated to personnel?**
-

### - — 4. Implement Procedures to Address These Requirements

Not assessed

**Progress:** To do

Identify and implement methods that will be used to protect ePHI from unauthorized modification.

Identify and implement tools and techniques to be developed or procured that support the assurance of integrity.

**Are current audit, logging, and access control techniques sufficient to address the integrity of ePHI?**
-

**If not, what additional techniques (e.g., quality control process, transaction and output reconstruction) can be utilized to check the integrity of ePHI?**
-

**Are technical solutions in place to prevent and detect the malicious alteration or destruction of ePHI (e.g., anti-malware, anti-ransomware, file integrity monitoring solutions)?**
-

**Can the additional training of users decrease instances attributable to human errors?**
-

### - — 5. Implement a Mechanism to Authenticate ePHI

Not assessed

**Progress:** To do

Implement electronic mechanisms to corroborate that ePHI has not been altered or destroyed in an unauthorized manner.

Consider possible mechanisms for integrity verification, such as:

**Are the uses of both electronic and non-electronic mechanisms necessary for the protection of ePHI?**
-

**Are appropriate electronic authentication tools available?**
-

**Are available electronic authentication tools interoperable with other applications and system components?**
-

**If ePHI is detected as altered by unauthorized users or improperly altered by authorized users, is a process in place to respond?**
-

**Is this response process tied to organizational incident management processes?**
-

### - — Implementation Specification (Addressable)

Not assessed

**Progress:** To do

Implement electronic mechanisms to corroborate that ePHI has not been altered or destroyed in an unauthorized manner.

### - — 6. Establish a Monitoring Process to Assess How the Implemented Process is Working

Not assessed

**Progress:** To do

Review existing processes to determine whether objectives are being addressed.

Continually reassess integrity processes as technology and operational environments change to determine whether they need to be revised.

**Are there reported instances of information integrity problems?**

-

**Have they decreased since integrity procedures were implemented?**

-

**Does the process, as implemented, provide a higher level of assurance that information integrity is being maintained?**

-

### - — 1. Determine Authentication Applicability to Current Systems/Applications

Not assessed

**Progress:** To do

Identify the methods available for authentication. Under the HIPAA Security Rule, authentication is the corroboration that a person is the one claimed (45 CFR § 164.304).

Identify points of electronic access that require or should require authentication. Ensure that the regulated entity's risk analysis properly assesses risks for such access points (e.g., risks of unauthorized access from within the enterprise could be different than those of remote unauthorized access).

Authentication requires establishing the validity of a transmission source and/or verifying an individual's claim that they have been authorized for specific access privileges to information and information systems.

**What authentication methods are available?**

-

**What are the advantages and disadvantages of each method?**

-

**Can risks of unauthorized access be sufficiently reduced for each point of electronic access with available authentication methods?**

-

**What will it cost to implement the available methods in the environment?**

-

**Are there trained staff who can maintain the system or should outsourced support be considered?**

-

**Are passwords being used?**

-

**If so, are they unique to the individual?**

-

**Is MFA being used?**

-

**If so, how and where is it implemented?**

-

### - — 2. Evaluate Available Authentication Options

Not assessed

**Progress:** To do

Weigh the relative advantages and disadvantages of commonly used authentication approaches.

There are three commonly used authentication approaches available:

MFA utilizes two or more authentication approaches to enforce stronger authentication.

Consider implementing MFA solutions when the risk to ePHI is sufficiently high.

**What are the strengths and weaknesses of each available option?**

-

**Which can be best supported with assigned resources (e.g., budget/staffing)?**

-

**What level of authentication is appropriate for each access to ePHI based on the assessment of risk?**

-

**Has the organization identified all instances of access to ePHI (including by services, vendors, or application programming interfaces [APIs]) and considered appropriate authentication requirements based on the risk assessment?**

-

**Has the organization considered MFA for access to ePHI that poses high risk (e.g., remote access, access to privileged functions)?**

-

**Has the organization researched available MFA options and made a selection based on risk to ePHI?**

-

**Is outside vendor support required to implement the process?**

-

**Are there password-less authentication options (e.g., biometric authentication) available that can sufficiently address the risk to ePHI?**

-

### - — 3. Select and Implement Authentication Options

Not assessed

**Progress:** To do

Consider the results of the analysis conducted under Key Activity 2, and select appropriate authentication methods based on the results of the risk assessment and risk management processes.

Implement the methods selected in organizational operations and activities.

**Has the organization's selection of authentication methods been made based on the results of the risk assessment?**

-

**If passwords are being used as an authentication element, are they of sufficient length and strength to protect ePHI?**

-

**Is this enforced by technical policies?**

-

**Has necessary user and support staff training been completed?**

-

**Have a formal authentication policy and procedures been established and communicated?**

-

**Has necessary testing been completed to ensure that the authentication system is working as prescribed?**

-

**Do the procedures include ongoing system maintenance and updates?**

-

**Is the process implemented in such a way that it does not compromise the authentication information (e.g., password file encryption, etc.)?**

-

### - — 1. Identify Any Possible Unauthorized Sources that May Be Able to Intercept and/or Modify the Information

Not assessed

**Progress:** To do

Identify all pathways by which ePHI will be transmitted into, within, and outside of the organization.

Identify scenarios (e.g., telehealth, claims processing) that may result in access to or modification of the ePHI by unauthorized sources during transmission (e.g., hackers, disgruntled workforce members, business competitors).

Identify scenarios and pathways that may put ePHI at a high level of risk.

**Have all pathways by which ePHI will be transmitted (e.g., file transfers, email, web portals, mobile apps, communications with servers or databases containing ePHI, online tracking) been identified?**
-

**Has a risk assessment been used to determine transmission pathways and scenarios that may pose high risk to ePHI?**
-

**What measures exist to protect ePHI in transmission?**
-

**Have appropriate protection mechanisms been identified for all scenarios and pathways by which ePHI is transmitted?**
-

**Is there an auditing process in place to verify that ePHI has been protected against unauthorized access during transmission?**
-

**Are there trained staff members to monitor transmissions?**
-

### - — 2. Develop and Implement Transmission Security Policy and Procedures

Not assessed

**Progress:** To do

Establish a formal written set of requirements for transmitting ePHI.

Identify methods of transmission that will be used to safeguard ePHI.

Identify tools and techniques that will be used to support the transmission security policy.

Implement procedures for transmitting ePHI using hardware and/or software, if needed.

**Have the requirements been discussed and agreed to by identified key personnel involved in transmitting ePHI?**
-

**Has a written policy been developed and communicated to system users?**
-

### - — 3. Implement Integrity Controls

Not assessed

**Progress:** To do

Implement security measures to ensure that electronically transmitted ePHI is not improperly modified without detection until disposed of.

**What security measures are currently used to protect ePHI during transmission?**
-

**What measures are planned to protect ePHI in transmission?**
-

**Is there assurance that information is not altered during transmission?**
-

### - — Implementation Specification (Addressable)

Not assessed

**Progress:** To do

Implement security measures to ensure that electronically transmitted ePHI is not improperly modified without detection until disposed of.

### - — 4. Implement Encryption

Not assessed

**Progress:** To do

Implement a mechanism to encrypt ePHI whenever appropriate.

**Is encryption reasonable and appropriate to protect ePHI in transmission?**

-

**Based on the risk assessment, is encryption needed to effectively protect the information from unauthorized access during transmission?**

-

**Has the organization considered the use of email encryption and automated confidentiality statements when emailing outside of the organization?**

-

**Is encryption feasible and cost-effective in this environment?**

-

**What encryption algorithms and mechanisms are available?**

-

**Are available encryption algorithms and mechanisms of sufficient strength to protect electronically transmitted ePHI?**

-

**Is electronic transmission hardware/software configured so that the strength of encryption used in transmitting ePHI cannot be weakened?**

-

**Have all applications used on devices that support the provisioning of health services been assessed to verify that strong transmission security is implemented?**

-

**Does the covered entity have the appropriate staff to maintain a process for encrypting ePHI during transmission?**

-

**Are workforce members skilled in the use of encryption?**

-

### - — Implementation Specification (Addressable)

Not assessed

**Progress:** To do

Implement a mechanism to encrypt ePHI whenever appropriate.

### - — 1. Contract Must Provide that Business Associates Will Comply with the Applicable Requirements of the Security Rule

Not assessed

**Progress:** To do

Contracts between covered entities and business associates must provide that business associates will implement administrative, physical, and technical safeguards that reasonably and appropriately protect the confidentiality, integrity, and availability of the ePHI that the business associate creates, receives, maintains, or transmits on behalf of the covered entity.

Readers may find useful resources in Appendix F, including OCR BAA guidance and templates that include applicable language.

**Does the written agreement between the covered entity and the business associate address the applicable functions related to creating, receiving, maintaining, and transmitting ePHI that the business associate is to perform on behalf of the covered entity?**

-

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

Contracts between covered entities and business associates must provide that business associates will implement administrative, physical, and technical safeguards that reasonably and appropriately protect the confidentiality, integrity, and availability of the ePHI that the business associate creates, receives, maintains, or transmits on behalf of the covered entity.

### - — 2. Contract Must Provide that the Business Associates Enter into Contracts with Subcontractors to Ensure the Protection of ePHI

Not assessed

**Progress:** To do

In accordance with § 164.308(b)(2), ensure that any subcontractors that create, receive, maintain, or transmit ePHI on behalf of the business associate agree to comply with the applicable requirements of this subpart by entering into a contract or other arrangement that complies with this section.

**Has the business associate identified all of its subcontractors that will create, receive, maintain, or transmit ePHI?**

-

**Has the business associate ensured that contracts in accordance with § 164.314 are in place with its subcontractors identified in the previous question?**

-

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

In accordance with § 164.308(b)(2), ensure that any subcontractors that create, receive, maintain, or transmit ePHI on behalf of the business associate agree to comply with the applicable requirements of this subpart by entering into a contract or other arrangement that complies with this section.

### - — 3. Contract Must Provide that Business Associates will Report Security Incidents

Not assessed

**Progress:** To do

Report to the covered entity any security incident of which it becomes aware, including breaches of unsecured PHI as required by § 164.410.

Maintain clear lines of communication between covered entities and business associates regarding the protection of ePHI as per the BAA or contract.

Establish a reporting mechanism and a process for the business associate to use in the event of a security incident or breach.

**Is there a procedure in place for reporting security incidents, including breaches of unsecured PHI by business associates?**

-

**Have key business associate staff been identified as points of contact in the event of a security incident or breach?**

-

**Does the contract include clear time frames and responsibilities regarding the investigation and reporting of security incidents and breaches?**

-

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

Report to the covered entity any security incident of which it becomes aware, including breaches of unsecured PHI as required by § 164.410.

### - — 4. Other Arrangements

Not assessed

**Progress:** To do

The covered entity complies with paragraph (a)(1) of this section if it has another arrangement in place that meets the requirements of § 164.504(e)(3).

**Has the covered entity made a good faith attempt to obtain satisfactory assurances that the security standards required by this section are met?**

-

**Are attempts to obtain satisfactory assurances and the reasons that assurances cannot be obtained documented?**

-

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

The covered entity complies with paragraph (a)(1) of this section if it has another arrangement in place that meets the requirements of § 164.504(e)(3).

### - — 5. Business Associate Contracts with Subcontractors

Not assessed

**Progress:** To do

The requirements of paragraphs (a)(2)(i) and (a)(2)(ii) of this section apply to the contract or other arrangement between a business associate and a subcontractor in the same manner as such requirements apply to contracts or other arrangements between a covered entity and business associate.

**Do business associate contracts or other arrangements between the business associate and its subcontractors include appropriate language to comply with paragraphs (a)(2)(i) and (a)(2)(ii) of this section?**

-

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

The requirements of paragraphs (a)(2)(i) and (a)(2)(ii) of this section apply to the contract or other arrangement between a business associate and a subcontractor in the same manner as such requirements apply to contracts or other arrangements between a covered entity and business associate.

### - — 1. Amend Plan Documents of the Group Health Plan to Address the Plan Sponsor’s Security of ePHI

Not assessed

**Progress:** To do

Amend the plan documents to incorporate provisions to require the plan sponsor to implement administrative, technical, and physical safeguards that will reasonably and appropriately protect the confidentiality, integrity, and availability of ePHI that it creates, receives, maintains, or transmits on behalf of the group health plan.

**Does the plan sponsor fall under the exception described in the standard?**

-

**Do the plan documents require the plan sponsor to reasonably and appropriately safeguard ePHI?**

-

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

Amend the plan documents to incorporate provisions to require the plan sponsor to implement administrative, technical, and physical safeguards that will reasonably and appropriately protect the confidentiality, integrity, and availability of ePHI that it creates, receives, maintains, or transmits on behalf of the group health plan.

### - — 2. Amend Plan Documents of the Group Health Plan to Address Adequate Separation

Not assessed

**Progress:** To do

Amend the plan documents to incorporate provisions to require the plan sponsor to ensure that the adequate separation between the group health plan and plan sponsor required by §164.504(f)(2)(iii) is supported by reasonable and appropriate security measures.

**Do plan documents address the obligation to keep ePHI secure with respect to the plan sponsor’s workforce members, classes of workforce members, or other persons who will be given access to ePHI?**

-

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

Amend the plan documents to incorporate provisions to require the plan sponsor to ensure that the adequate separation between the group health plan and plan sponsor required by §164.504(f)(2)(iii) is supported by reasonable and appropriate security measures.

### - — 3. Amend Plan Documents of the Group Health Plan to Address the Security of ePHI Supplied to the Plan Sponsors' Agents and Subcontractors

Not assessed

**Progress:** To do

Amend plan documents to incorporate provisions to require the plan sponsor to report any security incident of which it becomes aware to the group health plan.

**Do the plan documents of the group health plan address the issue of subcontractors and other agents of the plan sponsor implementing reasonable and appropriate security measures?**

-

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

Amend plan documents to incorporate provisions to require the plan sponsor to ensure that any agent to whom it provides ePHI agrees to implement reasonable and appropriate security measures to protect the ePHI.

### - — 4. Amend Plan Documents of Group Health Plans to Address the Reporting of Security Incidents

Not assessed

**Progress:** To do

Amend plan documents to incorporate provisions to require the plan sponsor to report any security incident of which it becomes aware to the group health plan.

Establish a specific policy for security incident reporting.

Establish a reporting mechanism and a process for the plan sponsor to use in the event of a security incident.

**Is there a procedure in place for security incident reporting?**

-

**Are procedures in place for responding to security incidents?**

-

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

Amend plan documents to incorporate provisions to require the plan sponsor to report any security incident of which it becomes aware to the group health plan.

### - — 1. Create and Deploy Policies and Procedures

Not assessed

**Progress:** To do

Implement reasonable and appropriate policies and procedures to comply with the standards, implementation specifications, and other requirements of the HIPAA Security Rule.

Consider the importance of documenting processes and procedures for demonstrating the adequate implementation of recognized security practices.

Periodically evaluate written policies and procedures to verify that:

**Are reasonable and appropriate policies and procedures to comply with each of the standards, applicable implementation specifications, and other requirements of the HIPAA Security Rule in place?**

-

**Are policies and procedures reasonable and appropriate given:**

-

### - — 2. Update the Documentation of the Policy and Procedures

Not assessed

**Progress:** To do

Change policies and procedures as is reasonable and appropriate at any time, provided that the changes are documented and implemented in accordance with the requirements of the HIPAA Security Rule.

**Is a process in place for periodically reevaluating the policies and procedures and updating them as necessary?**

-

**Should HIPAA documentation be updated in response to periodic evaluations, following security incidents, and/or after acquisitions of new technology or new procedures?**

-

**As policies and procedures are changed, are new versions made available and are workforce members appropriately trained?**

-

### - — 1. Draft, Maintain, and Update Required Documentation

Not assessed

**Progress:** To do

Document decisions concerning the management, operational, and technical controls selected to mitigate identified risks.

Written documentation may be incorporated into existing manuals, policies, and other documents or be created specifically for the purpose of demonstrating compliance with the HIPAA Security Rule.

Consider the importance of documenting the processes and procedures for demonstrating the adequate implementation of recognized security practices.

Use feedback from risk assessments and contingency plan tests to help determine when to update documentation.

**Are all required policies and procedures documented?**

-

**Should HIPAA Security Rule documentation be maintained by the individual responsible for HIPAA Security Rule implementation?**

-

**Should HIPAA Security Rule documentation be updated in response to periodic evaluations, following security incidents, and/or after acquisitions of new technology or new procedures?**

-

**Have dates of creation and validity periods been included in all documentation?**

-

**Has appropriate management reviewed and approved all documentation?**

-

**Are actions, activities, and assessments required by the Security Rule documented as appropriate?**

-

### - — 2. Retain Documentation for at Least Six Years

Not assessed

**Progress:** To do

Retain documentation required by paragraph (b)(1) of this section for six years from the date of its creation or the date when it last was in effect, whichever is later.

**Have documentation retention requirements under HIPAA been aligned with the organization’s other data retention policies?**

-

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

Retain documentation required by paragraph (b)(1) of this section for six years from the date of its creation or the date when it last was in effect, whichever is later.

### - — 3. Ensure that Documentation is Available to Those Responsible for Implementation

Not assessed

**Progress:** To do

Make documentation available to those persons responsible for implementing the procedures to which the documentation pertains.

**Is the location of the documentation known to all staff who need to access it?**

-

**Is availability of the documentation made known as part of education, training, and awareness activities?**

-

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

Make documentation available to those persons responsible for implementing the procedures to which the documentation pertains.

### - — 4. Update Documentation as Required

Not assessed

**Progress:** To do

Review documentation periodically and update as needed in response to environmental or operational changes that affect the security of the ePHI.

**Is there a version control procedure that allows for the verification of the timeliness of policies and procedures, if reasonable and appropriate?**

-

**Is there a process for soliciting input on updates of policies and procedures from staff, if reasonable and appropriate?**

-

**Are policies and procedures updated in response to environmental or operational changes that affect the security of ePHI?**

-

**When were the policies and procedures last updated or reviewed?**

-

### - — Implementation Specification (Required)

Not assessed

**Progress:** To do

Review documentation periodically and update as needed in response to environmental or operational changes that affect the security of the ePHI.

## Commitments

No commitments recorded.